Akira Ransomware Campaign Exploiting SonicWall SSL VPN Zero

Prepared by

Abdul Hariz bin Mohd Sarnudin (CBS24070218)
Muhammad Hazeeq bin Nurazalan (CBS24070509)
Aiman Danish bin Mohd Khairunnizam (CBS24070471)
Muhammad Danial bin Norhisam (CBS24070222

Case Summary

Beginning around mid-July 2025, multiple international incident-response firms such as Arctic Wolf, Huntress, Google Threat Intelligence Group, S-RM, Rapid7, Bitdefender independently observed a sharp spike in **Akira ransomware** intrusions in which the initial access vector was consistently a **SonicWall Gen 7 firewall with SSL VPN enabled**. Attackers were reaching full ransomware deployment in as little as 1.5-10 hours after initial VPN logon. Even against organizations with MFA enabled and recently rotated passwords which strongly suggested a zero-day vulnerability.

SonicWall's own investigation, concluded on 6-7 August 2025, determined with high confidence that the activity was not a new zero-day, but instead traced back to **incomplete remediation of CVE-2024-40766**, an improper access control vulnerability in SonicOS (CVSS 9.8) originally disclosed in August 2024. The root cause in most cases was local VPN account passwords that were carried over during Gen 6 to Gen 7 firewall migrations and never reset, combined with over-privileged service accounts and a misconfigured **"SSLVPN Default Users Group."**

This case study covers the vulnerability, the threat actor, the full attack chain, the campaign timeline, impact, and recommended mitigations. It consistent with the advisory issued by MyCERT/CyberSecurity Malaysia and the joint CISA/FBI #StopRansomware advisory on Akira.

The Vulnerability

01

CVE-2024-40766 — SonicOS Improper Access Control

- Disclosed: 22 August 2024 (SonicWall advisory SNWLID-2024-0015)
- **Affected devices**: SonicWall Gen 5, Gen 6, and Gen 7 firewalls with SSL VPN enabled, firmware versions up to and including 7.2.0-7015
- **Root cause**: Improper access control in SonicOS management access and SSL VPN, which could allow unauthorized resource access and, in some conditions, cause the firewall to crash
- **September 2024 update**: SonicWall expanded the advisory scope to confirm the flaw also affected local SSL VPN user accounts, not just management access, after evidence of active exploitation emerged

02

Why It Resurfaced as a "Suspected Zero-Day" in 2025

Despite being patched in 2024, three compounding factors allowed continued exploitation into mid-2025:

1. **Unremediated password carryover** — organizations that migrated firewalls from Gen 6 to Gen 7 retained old local-user passwords instead of resetting them as SonicWall's original advisory instructed.
2. **The "SSLVPN Default Users Group" misconfiguration** — in certain configurations this over-provisioned SSLVPN access via default LDAP group settings.
3. **An exposed Virtual Office Portal** — publicly reachable in some deployments, allowing attackers with previously breached credentials to self-configure MFA/TOTP for accounts they didn't legitimately own.

Impact

- **Scope**: The attackers are achieving rapid network compromise, bypassing even MFA protections, and deploying ransomware within minutes of initial access. Even fully patched SonicWall appliances appear to be at risk, and conventional authentication mechanisms may be bypassed.
- **Operational disruption**: Encryption of production Windows servers and VMware ESXi hosts deleted backups complicating recovery.
- **Data exposure**: Double-extortion tactic where exfiltrated data threatened for publication on Akira's Tor leak site regardless of ransom payment.
- **Trust & compliance impact**: Reputational damage, regulatory exposure, and business interruption costs, particularly for SMBs and mid-market firms relying on MSP-managed SonicWall deployments.
- **Malaysia-specific relevance**: MyCERT/Cyber999 flagged this campaign under advisory *(MA-1373.082025)* as part of its ongoing monitoring of ransomware activity affecting Malaysian organizations, consistent with prior Akira-specific advisories and its broader ransomware best-practices guidance.

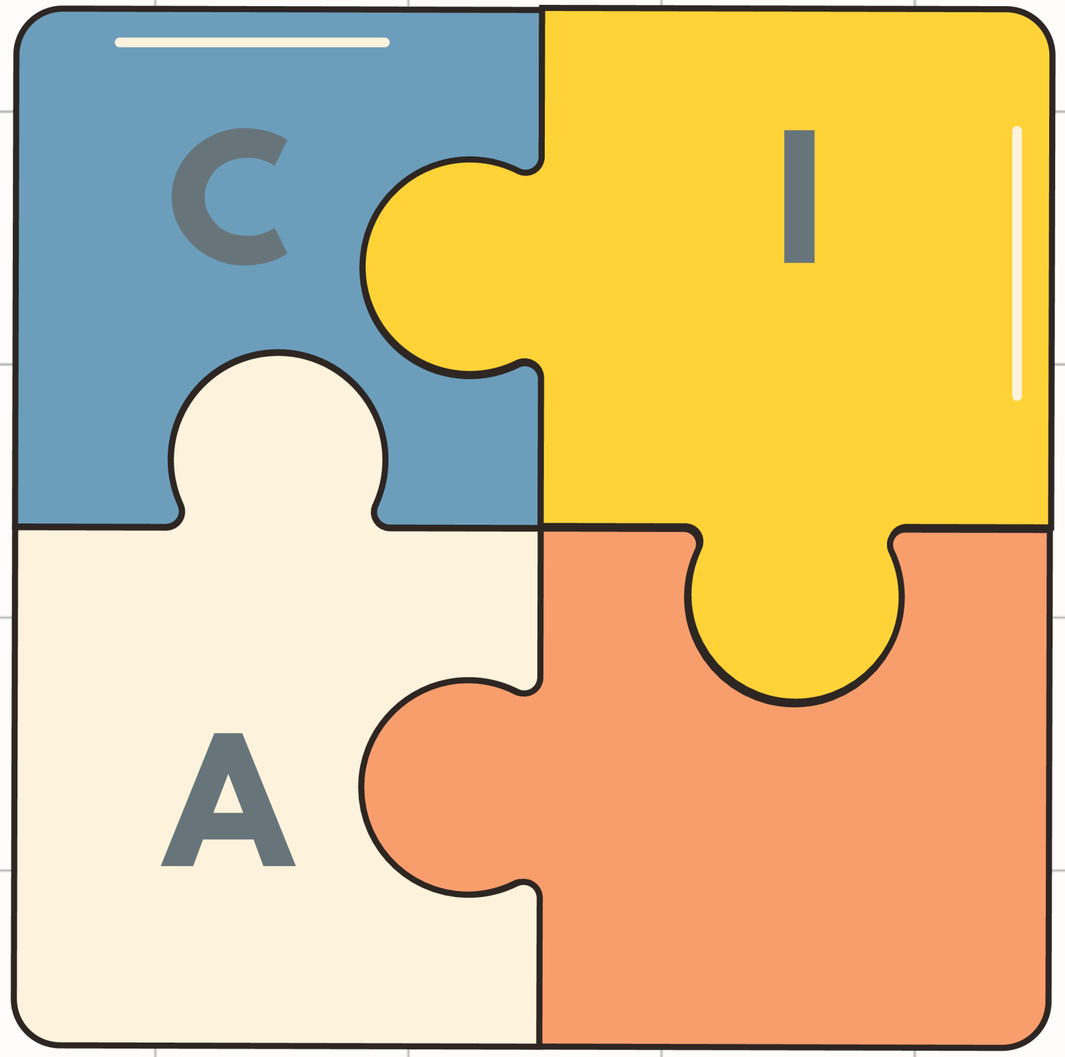
How C.I.A Relate To Ransomware

Confidentiality

Attackers bypass MFA and perimeter defense to gain unauthorized access to sensitive internal network data.

Availability

The exploit bypasses conventional authentication and masks traffic through external ASNs, making it incredibly difficult to accurately track or audit the attackers' true identities and actions.



Integrity

Threat actors deploy Akira ransomware within minutes, maliciously encrypting and altering files to render them unusable.

How C.I.A Relate (Cont.)

Confidentiality

Confidentiality is about ensuring only the right people have the keys to our data.

In the Akira Ransomware attack, the hackers broke through the perimeter defense by exploiting vulnerable VPN connections that lacked Multi-Factor Authentication (MFA), or by using phishing to steal real user credentials.

Integrity

Integrity means your data remains exactly as it should be.

Complete and untampered with. Akira ransomware ruins this by scrambling (encrypting) our files so we can no longer read or use them. We can also check this by comparing the license and hashes.

Availability

Availability means that our systems, computers, and data are online and ready to use whenever our employees or customers need them.

Akira attacks availability in the most destructive way possible: they encrypt our files and systematically delete your backups. By doing this, they ensure we cannot run our business, and we cannot easily restore our systems to get back online.

Cryptographic Solutions



Strengthen SonicWall VPN Authentication

- Reset all local SSL VPN passwords carried over from Gen 6 to Gen 7.
- Enforce MFA for every SSL VPN account; where supported, add certificate-based authentication.



Protect Credentials and Certificates

- Rotate credentials that may have been exposed after an administrator compromise.
- Revoke and replace VPN certificates only if their private keys may have been exposed.



Protect Ransomware Recovery

- Keep critical backups offline or immutable and encrypt them using strong encryption such as AES-256.
- Store decryption keys separately and verify backup integrity before restoration.

Tour D'Horizon

To encapsulate the case study, Cryptography is cybersecurity's ultimate double-edged sword. A math-based shield that when stolen and squander by threat actors like the one who design ransomwares, in this case Akira Ransomware, is weapoonized to systematically crush the Confidentiality, Integrity as well as the Availibity of a system or a whole organizations.

Ultimately, Akira proves that the CIA Triad isn't just a theoretical textbook model, but a high stakes battlefield where the side that controls the cryptographic keys control the survival of the bussiness and digital system.



DANKE SCHON